AIORI-3 HACKATHON · CYBER SECURITY TRACK

PS-002: Purpose-Based Consent Recording & Withdrawal Prototype

TEAM NAME	PROBLEM CODE	SYNTHETIC SERVICE	TARGET FRAMEWORKS
SPARK	PS-002	HealthPulse Portal	India DPDP 2023 / GDPR

1. Executive Summary & Problem Context

Modern privacy legislation, such as **India's Digital Personal Data Protection (DPDP) Act, 2023 (Section 6)** and the **EU GDPR (Articles 6 & 7)**, mandates that personal data must only be processed for explicit, itemized purposes, and that processing must cease immediately upon consent withdrawal.

In conventional enterprise architectures, backend systems often record consent flags in a database but fail to enforce those boundaries across downstream data flows. Downstream microservices, analytics pipelines, and third-party consumers continue accessing data indiscriminately. **ConsentGuard** solves this architectural vulnerability by establishing a real-time **Policy Enforcement Point (PEP)** and cryptographic privacy notice ledger (SHA-256) that dynamically gatekeeps data sharing and guarantees instantaneous revocation.

2. System Architecture & Core Specifications

ConsentGuard is structured into three integrated tiers designed around zero-trust consent verification:

- **Tier 1: Consent Ledger & Notice Center (Frontend UI):** An interactive dashboard presenting itemized consent options across 3 dedicated purposes (*Analytics*, *Marketing*, and *Service Improvement*), live SHA-256 notice fingerprint display, and a 5-step guided demonstration runner.
- **Tier 2: Real-Time Policy Enforcement Point (Flask API):** The gatekeeper service intercepting all downstream data requests (`/api/data-access`). It queries the consent ledger in real time, compares notice version numbers, and validates cryptographic digests before releasing mock synthetic payloads.
- **Tier 3: Cryptographic Audit Ledger (SQLite DB):** An append-only audit trail capturing every grant, withdrawal, denial, notice modification, and timestamp in UTC for evidentiary compliance.

Data-Sharing Purposes & Mock Synthetic Payload Mapping

Purpose	Technical Scope	Synthetic Mock Fields Released (HTTP 200)
Analytics	User journey signals & interface telemetry	`page_views`, `feature_usage`
Marketing	Campaign segmentation & partner offers	`email_preferences`, `offers_enabled`
Service Improvement	System health benchmarks & latency metrics	`app_performance_ms`, `recent_error_count`

3. Key Innovations & Technical Highlights

- **Cryptographic Notice Versioning (SHA-256):** Rather than relying on simple text descriptions, ConsentGuard computes a SHA-256 digest of the active privacy notice. If the privacy notice is updated (e.g., from v1.0 to v2.0), all existing consents are automatically rendered *stale* by the enforcement logic without destructive database operations.

- **Sub-Millisecond Revocation Enforcement:** Revoking consent immediately flips the database state and is logged to the audit trail. Subsequent calls to the downstream mock consumer are rejected with HTTP 403 Forbidden with zero data leakage.
- **Purpose Isolation:** Granting consent for *Analytics* provides zero authorization for *Marketing* or *Service Improvement*, upholding strict purpose specification requirements.

4. Prototype Demonstration with Pseudocode Snippet (Deliverable #3)

The core enforcement logic operating at the downstream boundary is implemented as a **Policy Enforcement Point (PEP)** algorithm that evaluates both active consent status and notice version validity:

```
Algorithm: Downstream Policy Enforcement Point (PEP) Gatekeeper
-----------------------------------------------------------------
FUNCTION EnforceDataAccess(userId, requestedPurpose):
    // Step 1: Validate purpose against inventory
    IF requestedPurpose NOT IN { "Analytics", "Marketing", "Service Improvement" }:
        RETURN HTTP 400 ("Invalid Purpose")

    // Step 2: Query active consent ledger
    consentRecord = DB.Query("SELECT granted, notice_version FROM consents
                              WHERE user_id = ? AND purpose = ?", userId, requestedPurpose)

    // Step 3: Fetch active privacy notice version & SHA-256 digest
    activeVersion, activeHash = System.GetNoticeMetadata()

    // Step 4: Strict Policy Boundary Verification
    IF consentRecord IS NULL:
        LogAudit(userId, requestedPurpose, "data_access_denied", "Explicit opt-in required")
        RETURN HTTP 403 ("Access Denied: No consent on record")

    IF consentRecord.granted != 1:
        LogAudit(userId, requestedPurpose, "data_access_denied", "Consent revoked/withdrawn")
        RETURN HTTP 403 ("Access Denied: Consent withdrawn")

    IF consentRecord.notice_version != activeVersion:
        LogAudit(userId, requestedPurpose, "data_access_denied", "Notice version obsolete")
        RETURN HTTP 403 ("Access Denied: Privacy notice changed; fresh consent required")

    // Step 5: Authorization granted
    LogAudit(userId, requestedPurpose, "data_access_allowed", "PEP verified active consent; SHA256=" + activeHash)
    RETURN HTTP 200 (MOCK_DATA[requestedPurpose])
```

Mandatory 5-Stage Lifecycle Sequence (From Problem Statement)

ConsentGuard provides an interactive one-click automated walkthrough that demonstrates the exact lifecycle sequence required by the PS-002 evaluation criteria:

1. **Grant:** Synthetic user grants `Analytics` consent under Notice v1.0. (HTTP 201 Created).
2. **Data Sharing:** Downstream consumer calls `/api/data-access` and receives mock synthetic payload. (HTTP 200 OK).
3. **Withdrawal:** User invokes their right to withdraw; consent record is updated. (HTTP 201 Created).
4. **Denied Subsequent Request:** Downstream consumer makes immediate re-request; PEP gatekeeper blocks access. (HTTP 403 Forbidden).
5. **Notice Change:** Privacy notice is bumped to v2.0 (new SHA-256 computed); pre-existing consents are invalidated until re-consent is recorded.

5. Testing & Verification Suite

The solution includes two layers of automated verification:

- **18 Automated Python Unit Tests (`backend/test_api.py`):** Automated test suite verifying health endpoints, purpose isolation, withdrawal denial, invalid purpose handling, user boundaries, dynamic notice updates, and CSV audit

exporting. All 18 tests pass with `OK`.

- **14 Live Frontend Lifecycle Tests (`index.html`):** In-browser test runner executing real HTTP requests against the live API and reporting PASS/FAIL status in real time.

6. Regulatory Compliance Alignment Table

Regulatory Requirement	Legal Basis	ConsentGuard Implementation
Itemized, Specific Purpose	DPDP Act Sec 6(1) / GDPR Art 6	Separate database records for Analytics, Marketing, and Service Improvement.
Right to Withdraw Consent	DPDP Act Sec 6(4) / GDPR Art 7(3)	Immediate revocation endpoint updating database and blocking downstream access.
Notice Accuracy & Versioning	DPDP Act Sec 5 / GDPR Art 13	SHA-256 notice hashing; access blocked if consent notice version != active notice version.
Demonstrable Audit Evidence	DPDP Act Sec 6(10) / GDPR Art 5(2)	Append-only SQLite audit log with UTC timestamps and one-click CSV export.

7. GitHub Collaboration Deliverable Checklist

- [x] Private GitHub repository initialized: `https://github.com/Pradeep007-1/ConsentGuard.git`
- [x] Collaborator invitation prepared for `aiori-hackathon` account.
- [x] Submission document compiled: `Proposed-structure-hackathon.pdf`.
- [x] Live prototype verified and ready for mentor demonstration.